PHASE 1 · EMPIRICAL EVALUATION · AUGUST 2026

Is LEV calibrated?

NIST's *Likely Exploited Vulnerabilities* metric assigns every CVE a probability that it has already been exploited. This report checks those probabilities against what was actually observed. They rank vulnerabilities well, but are over-confident by a large multiple — for three causes that can be separated and measured.

Evaluating NIST CSWP 41 (Mell & Spring, May 2025) · 367,311 CVEs · 67 EPSS snapshots, 2021-04-14 to 2026-08-01 · CISA KEV as of 2026-08-25 · analysis date 2026-08-01

17.2×
LEV over-predicts KEV appearance, as the metric is defined today

3.4–4.1×
still over-predicting after correcting every measurable source of error

4 / 4
of NIST's published Table 5 values reproduced, all within 11%

The two quantities being compared

LEV **A prediction.** It takes EPSS — a daily score estimating the chance a vulnerability is exploited in the next 30 days — and compounds it across every 30-day window since the CVE first appeared. A CVE scoring a modest 3% every month for two years accumulates a high LEV, because the chances multiply up.

KEV **An observation.** CISA's Known Exploited Vulnerabilities catalog lists vulnerabilities confirmed as exploited in the wild: 1,676 entries against roughly 367,000 CVEs.

If LEV were calibrated, CVEs it scores at 0.30 would appear in KEV about 30% of the time. That is the entire test.

predicted — LEV observed — KEV

FIRST, DOES THE CODE WORK

The implementation reproduces NIST's own numbers

Before interpreting anything, the LEV implementation has to match the paper. CSWP 41 publishes four average-LEV values. All four reproduce — using monthly rather than daily EPSS data, at the paper's own analysis date.

POPULATION	NIST	THIS CODE	DIFFERENCE	
Published since 2023-03-07	0.015	0.0162	+8%	reproduced
Published since 2022-02-04	0.047	0.0479	+2%	reproduced
Published since 2021-04-14	0.087	0.0838	−4%	reproduced
All CVEs, no version restriction	0.146	0.1299	−11%	reproduced

> **This validates the code, not the metric.** Agreement holds only at the paper's analysis date. Recomputed at today's date, the same first row runs +296% — because LEV grows every month by construction, which turns out to be one of the findings.

THE HEADLINE RESULT

Ranking works. The probabilities do not.

105,250 CVEs old enough to judge, of which 495 appear in KEV. Sorted into ten buckets by LEV score, the observed KEV rate climbs steadily — from 0.03% in the lowest bucket to 12.9% in the highest. As a way to *order* vulnerabilities by risk, LEV works.

But read the two number columns against each other. In the bucket where LEV claims 99%, 12.9% of CVEs actually appear. Every bucket sits far below the line it claims.

LEV BUCKET	CVES	PREDICTED	OBSERVED	IN KEV	OBS / PRED
0.0 – 0.1	90,599	2.6%	0.03%	24	0.010
0.1 – 0.2	5,802	13.7%	0.50%	29	0.036
0.2 – 0.3	2,031	24.5%	0.89%	18	0.036
0.3 – 0.4	1,166	34.7%	1.54%	18	0.045
0.4 – 0.5	869	45.0%	1.84%	16	0.041
0.5 – 0.6	702	54.9%	1.00%	7	0.018
0.6 – 0.7	564	65.0%	2.13%	12	0.033
0.7 – 0.8	492	74.9%	3.86%	19	0.052
0.8 – 0.9	435	84.9%	4.14%	18	0.049
0.9 – 1.0	2,590	**98.7%**	**12.90%**	334	**0.131**

> **Careful with the middle of that curve.** Only 2 of the 9 bucket-to-bucket differences survive correction for multiple comparisons; the seven middle buckets are statistically indistinguishable from each other. The dip at 0.5–0.6 is 7 CVEs out of 702 — noise, not signal. Claim a three-level discriminator, not a graded scale.

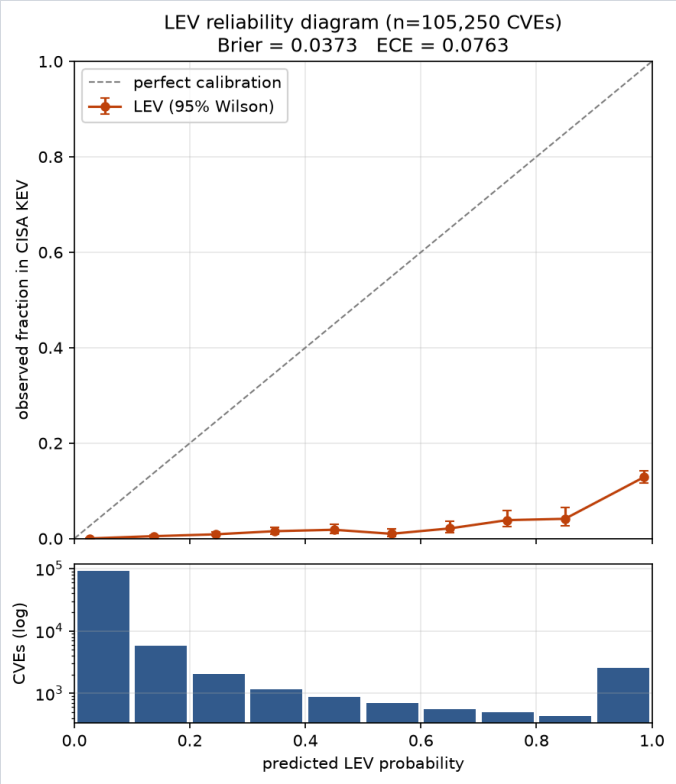


Figure 1. The dashed diagonal is perfect calibration; the plotted curve is LEV. It rises — ranking works — but never approaches the line. Error bars are 95% Wilson intervals. The lower panel shows how few CVEs occupy the middle buckets.

WHY THE GAP EXISTS

Three separable causes

A 17× gap could mean the metric is broken, or that the yardstick is incomplete. It is measurably some of each. These three were isolated and quantified independently of one another.

26.9%

EPSS changed underneath it

LEV multiplies EPSS scores across years, including across EPSS model retrainings. On one day — 2025-03-17 — a new EPSS model tripled scores corpus-wide. LEV absorbs that as accumulated evidence of exploitation. Just over a quarter of all LEV mass is this artifact.

14×

KEV sees some vendors better

Among CVEs LEV scores *identically*, 32.5% of Microsoft's appear in KEV against 2.3% of XWiki's. Exploitation propensity is assumed equal at equal LEV, so this spread is visibility, not risk — the catalog is a partial view.

no ceiling

LEV grows without saturating

LEV can only increase as time passes. It was expected to level off as EPSS decays for old CVEs. It does not: growth is convex, and cohort EPSS *rises*. Left running, the metric drifts toward 1.0 for everything and stops discriminating.

The EPSS retraining, caught in a single day

The model version string reads `v2025.03.14`, but that is a build date — the file carrying it first appears on 2025-03-17. Bracketing the correct day, on an unchanged set of 13,552 CVEs, mean EPSS jumps from 0.0086 to 0.0264 overnight. Nothing about those vulnerabilities changed.

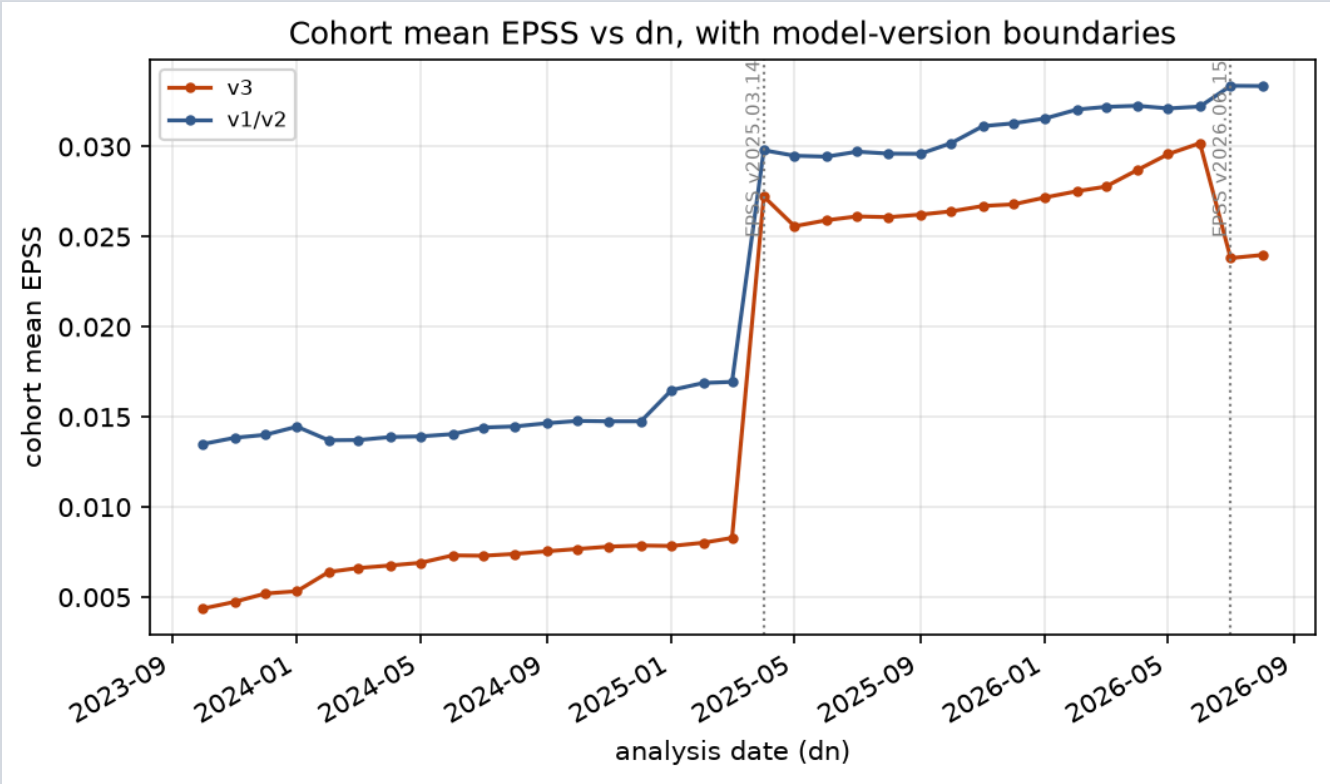


Figure 2. Cohort mean EPSS over time; dotted lines mark EPSS model retrainings. The near-vertical step in March 2025 is a model change, not vulnerability behaviour. 64% and 70% of each cohort's total EPSS rise happens at these boundaries rather than between them.

Growth that does not level off

Holding a fixed set of CVEs and moving only the analysis date forward, mean LEV runs from 0.008 to 0.135 over 35 months. A quadratic fits better than linear, logarithmic or saturating curves — the growth is *accelerating*. The

premise behind the expected slowdown fails too: EPSS for these cohorts rises rather than decaying.

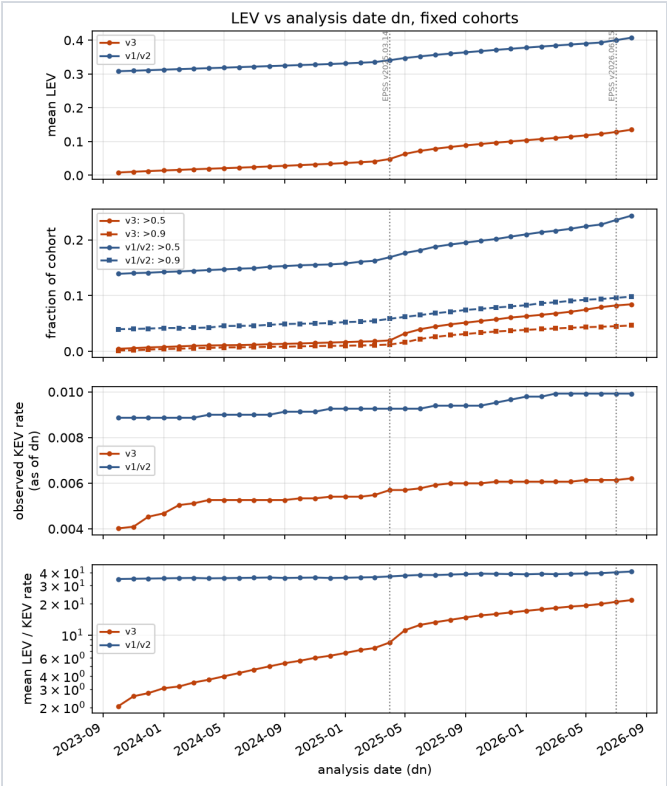


Figure 3. The same CVEs throughout; only the analysis date moves. Mean LEV and the fraction above 0.5 and 0.9 climb steadily, while the observed KEV rate (third panel) stays nearly flat — so the ratio between them, bottom panel, keeps widening.

NARROWING THE NUMBER

How big is the gap really?

Each correction removes one measurable source of error, so each figure is a tighter *upper* bound on how over-confident LEV is. This is a genuine sequence: every step assumes the one before it.

17.2×	**Raw comparison** LEV as the paper defines it, against KEV as it stands. Brier score 0.037, expected calibration error 0.076.
12.6×	**After removing EPSS version shift** Rescaling every post-retraining score back onto the old model's scale removes 26.9% of LEV mass. A 27% reduction — material, but far from the whole gap. Version mixing and calibration error are overlapping problems, not one problem.
3.4–4.1×	**After allowing for what KEV misses** If the best-observed vendor stratum shows what full visibility looks like, true exploitation is 1,123–1,369 CVEs against the 441 recorded. Two independent estimators agree to within 1.22×.

> **Read 3.4–4.1× as a ceiling, not a measurement.** It assumes Microsoft's vulnerabilities are *fully* observed, which is certainly false, so the true figure is lower. But LEV remains over-confident by a multiple, not by a few percent, and no correction available here closes that.

> **One check that came out the useful way.** If high-KEV vendors were simply attacked more, the vendor spread would be real risk rather than visibility. Tested inside a single LEV bucket, they score *lower* on every exploitation signal — less EPSS persistence, lower CVSS — yet still land in KEV far more often. The confound would need the opposite sign.

CONFIDENCE

What would survive review, and what would not

Solid

- All four Table 5 values reproduce — the implementation is correct.
- The 26.9% version-mixing share is measured two independent ways, daily and monthly, that agree.
- The vendor visibility spread is significant on all eight features tested, after correction.
- Monthly rather than daily EPSS sampling costs 3.9%, measured on 479 CVEs against true daily windows — and it is unsigned, so it adds noise rather than bias.
- Version normalization preferentially removes false positives: the CVEs it demotes are 3× less likely to be in KEV.

Not settled

- The 3.4–4.1× bound rests on three LEV buckets, and its top ceiling comes from two vendors.
- Whether the residual gap is metric error or catalog incompleteness is *constrained*, not decided — the test that addresses it is underpowered.
- KEV records when CISA learned of exploitation, not when it happened, so every timing comparison is lagged by an unknown amount.
- Rescaling EPSS versions by percentile cannot separate a corpus-wide shift from genuine model improvement, so it strips some real signal too.
- The sampling-error measurement covers the calibration cohort, not the older CVEs behind the Table 5 rows.

> The full list runs to 40 documented threats to validity, each pinned to the line of code that introduces it.

Method check: does monthly sampling matter?

The pipeline reads EPSS once a month, but LEV windows are exactly 30 days — so late windows read a score up to two weeks off the date the equation asks for. Measured against true daily windows on 479 CVEs: 3.9% of mean LEV, with no systematic direction. Small enough to set aside.

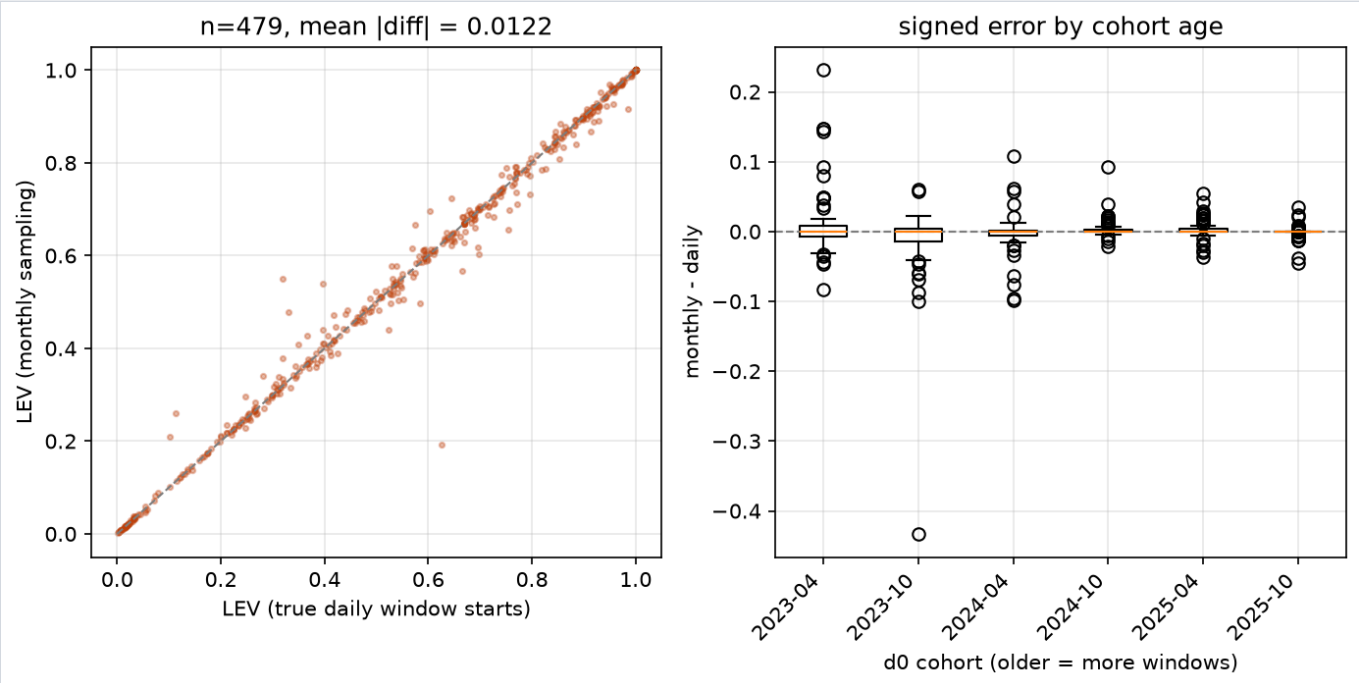


Figure 4. Left: monthly-sampled LEV against LEV computed on true daily windows — tight on the diagonal. Right: the error by cohort age, centred on zero throughout but spreading as more 30-day windows accumulate.

DATA

The data this rests on

Every number in this report comes from these five sources at these exact versions. Each row states what the source was used for and the known limitation a reader should weigh against it.

SOURCE	VERSION AND SIZE	USED FOR	KNOWN LIMITATION
EPSS epss.empiricalsecurity.com	67 monthly snapshots, 2021-04-14 to 2026-08-01. 14,456,555 rows, 367,311 unique CVEs. Plus 28 daily files for retraining-boundary probes.	The sole input to LEV. Every LEV value is a product over these scores.	Sampled monthly, not daily — measured cost 3.9% of mean LEV, unsigned. Spans three model retrainings, one of which tripled scores overnight.
CISA KEV cisa.gov	catalogVersion 2026.08.25, 1,676 entries, dateAdded 2021-11-03 to 2026-08-25. SHA-256 `4ddd6177…3bb79`.	The only exploitation ground truth. Defines "observed" throughout.	**Three problems.** Incomplete by design; `dateAdded` is when CISA catalogued, not when exploitation happened; and it is an input *feature* to EPSS, so it is partly a predictor of the thing it is scoring.
CVE List v5 CVE Program	Release `cve_2026-08-25_1700Z`, 192,054 records (CVE-2022 onward). 80.5% carry CVSS v3, 81.9% vendor, 81.4% CWE. SHA-256 `87ca8c2c…51e823`.	CVSS, CWE and vendor attribution for the top-bucket stratification.	Vendor names are unnormalised CNA free text; multi-product CVEs are attributed to the first product listed. Per-vendor counts are lower bounds.
Exploit-DB gitlab.com/exploit-database	47,135 rows covering 25,057 CVEs. SHA-256 `54b9167e…df9487`. Committed to the repository.	Public-exploit availability, as one feature separating KEV from non-KEV CVEs.	Availability is not exploitation. Also an EPSS input feature, so it correlates with LEV by construction.
Metasploit rapid7/metasploit-framework	7,151 modules covering 3,185 CVEs. SHA-256 `c155aa27…3e5ee99`. Committed to the repository.	As above. Combined with Exploit-DB: 26,311 unique CVEs with a public exploit.	As above.

The population actually analysed

From 367,311 CVEs with any EPSS data, the calibration cohort is **105,250** — those first scored in the EPSS v3 era (2023-03-07 onward), excluding CVEs that EPSS backfilled retroactively, and at least six months old so they have had a chance to appear in KEV. **495 of them are in KEV**, a base rate of 0.47%. Table 5 reproduction uses larger populations at an earlier analysis date; every other figure here uses the 105,250.

> **What is not here.** No second exploitation source, no daily EPSS, and no data on exploitation that no catalogue recorded — which is why the residual gap cannot be split between LEV error and catalogue incompleteness. That sets the Phase 2 agenda.

> **Reproducibility.** `make reproduce` rebuilds every table and figure offline. Provenance is pinned in `DATA_SNAPSHOT.md`, the EPSS end date is pinned in code so re-runs cannot ingest newer snapshots, and the two sources served from moving branches are committed to the repository.

ASSESSMENT

Is there a paper in this?

Yes — but as a measurement paper about *why* LEV and KEV disagree, not as a verdict on whether LEV is calibrated.

The framing matters more than the results here. “LEV over-predicts KEV by 17×” is the weakest defensible claim in this project, and a reviewer closes it in one line: KEV is known to be incomplete, so disagreement with KEV is expected and on its own measures nothing. What survives is the *decomposition* — not that a gap exists, but that it can be taken apart and attributed. Two of the findings below use no exploitation ground truth at all, so that objection does not reach them.

FINDING	WHY IT HOLDS, OR DOES NOT	STRENGTH
EPSS retraining contaminates LEV by 26.9%	Novel, quantified, and causally identified from a one-day step on a fixed CVE set. Actionable: published LEV values are partly an artifact of EPSS version history. Uses no ground truth.	**Strongest**
LEV growth is convex and never saturates	Directly falsifies a stated premise of CSWP 41 — that EPSS decays for old CVEs. Measured from EPSS alone, so KEV incompleteness cannot be raised against it.	**Strong**
Visibility bias within one LEV stratum	A 14× vendor spread among identically-scored CVEs operationalises NIST’s own error source #4. The falsification check ran the right way: high-KEV vendors show *less* exploitation signal, not more.	**Strong**
Independent reproduction of Table 5	Establishes that the implementation is trustworthy. Necessary for everything above, but not a contribution standing alone.	**Supporting**
Vendor-ceiling bound on KEV completeness	Rests on three LEV buckets, with two vendors setting the top ceiling. Report it as a bound; do not build an argument on it.	**Weakest**

Before anything is submitted

1. **Run the literature search.** CSWP 41 is from May 2025 and no search has been done, so nothing here is confirmed novel. This check governs how hard the contribution claim can be pushed and should happen first.
2. **Add a second exploitation signal.** GreyNoise, Shadowserver or VulnCheck KEV. This is what separates “LEV is wrong” from “the catalog is partial” — the one question every analysis here constrains but none decides.
3. **Recompute on daily EPSS if a claim turns on it.** Monthly sampling costs a measured 3.9% and is unsigned, which is fine for everything above; it would not be fine for a claim resting on a difference of that size.
4. **Lead with the two ground-truth-free findings.** They are the ones a reviewer cannot deflect, and they carry the reproduction and the bias result with them.

> **The honest limitation to state up front.** This work shows that LEV and KEV disagree, and decomposes the disagreement into measurable parts. It does not establish how much of the residual gap is LEV error versus catalog incompleteness. Claiming otherwise from a single ground-truth source would not survive review — and stating the limit plainly is stronger than hedging it.

Phase 1 — 4 data modules, 1 model implementation, 11 analyses, 4 figures, 44 recorded threats to validity.
Evaluating NIST CSWP 41, Mell & Spring, *Likely Exploited Vulnerabilities*, May 2025. Analysis date 2026-08-01.